

You ship pieces. Nothing carries the release.

You sign the pieces. Nothing signs the release.

Open Component Model — open source, NeoNephos Foundation.



DIAGNOSIS

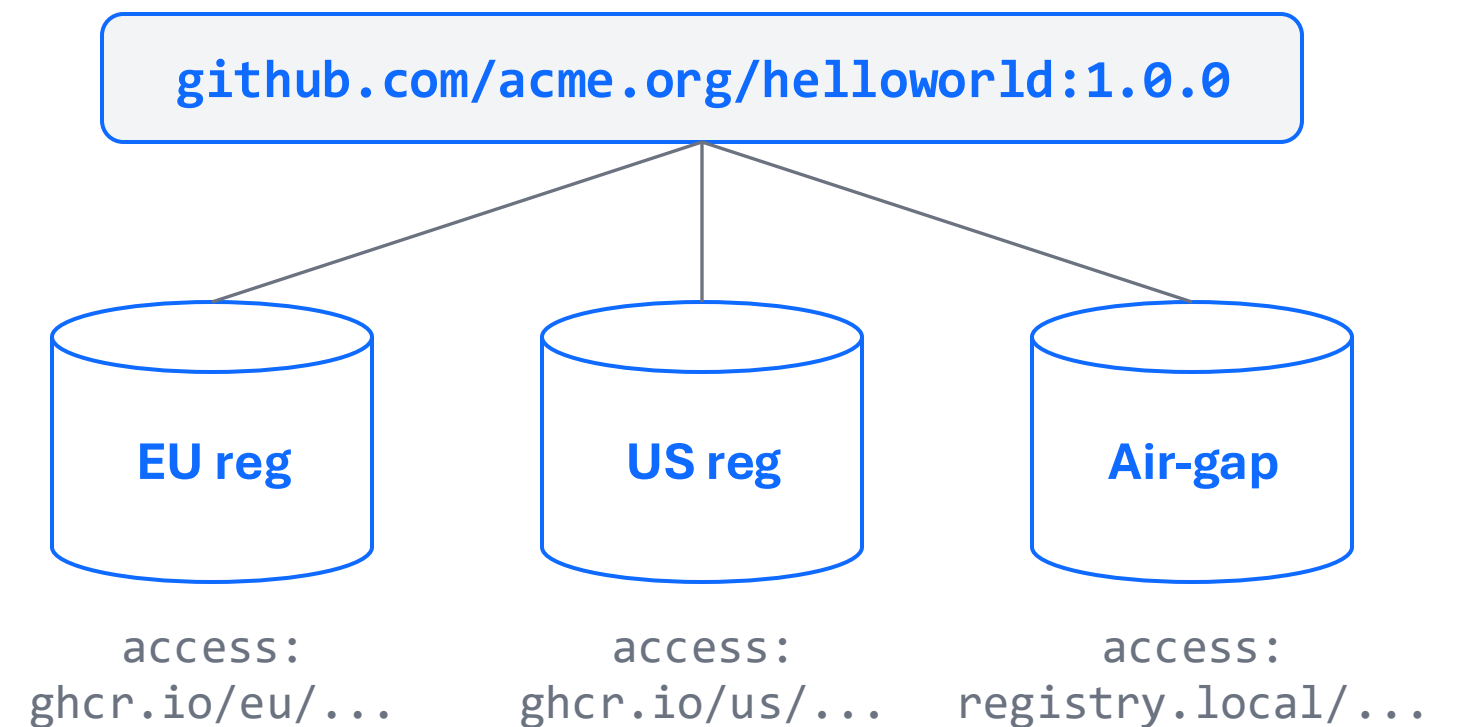
In every existing tool, identity is bound to location.

- **OCI image** — digest pins the bytes. Nothing pins the release the image belongs to.
- **Helm chart** — version pins the chart. Nothing pins it to the image, config, and SBOM it ships with.
- **SBOM** — referrer attaches to one digest. No referrer spans the whole release.

THE HINGE

Identity that travels with the artifact.

- **Component identity** — name and version of the component. Globally unique. Location-agnostic.
- **Digest** — every resource inside the component carries a content hash. Computed once.
- **Access** — where the resource currently lives. Rewritten on transfer. Digest stays.



Move the artifact. The digest stays. Only the access changes.

WHERE OCM SITS

Wraps every artifact. Signs the whole release.

ANY FORMAT

OCI, Helm, configs, SBOMs, npm, maven, binaries.

Artifact type is free-form; access types are pluggable.

ANY LOCATION

Component identity travels.

The component carries its name across registries.

ONE SIGNATURE

Covers every digest in the component.

Survives transport.

CONSTRUCTOR

What you write.

```
components:
- name: github.com/acme.org/helloworld
  version: 1.0.0
  provider:
    name: acme.org
  resources:
    - name: mylocalfile
      type: blob
      input:                                # Embed by value
        type: File/v1
        path: ./my-local-resource.txt

    - name: image
      type: ociImage
      version: 1.0.0
      access:                               # Reference external artifact
        type: OCIImage/v1
        imageReference: ghcr.io/stefanprodan/podinfo:6.9.1
```

DESCRIPTOR

What gets signed and travels.

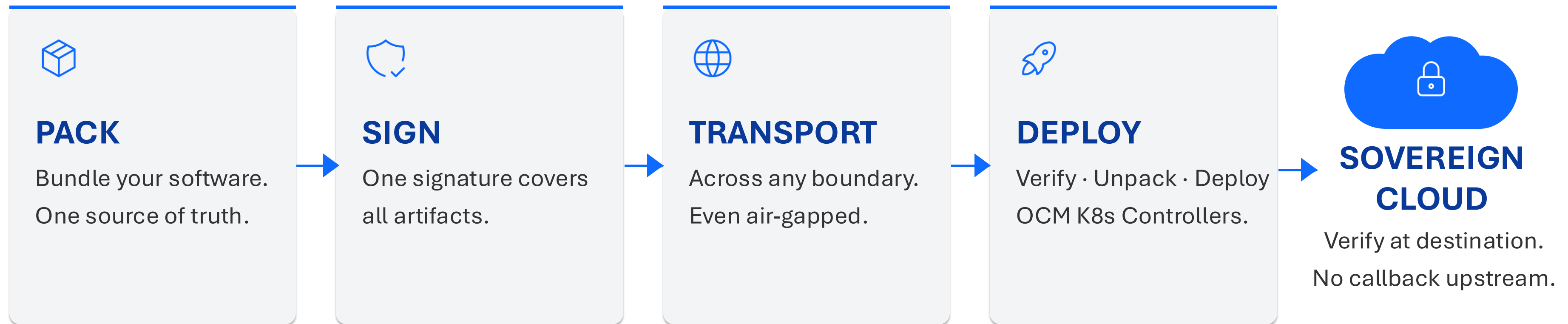
```
component:                                # (fields trimmed)
  name: github.com/acme.org/helloworld
  version: 1.0.0
  resources:
    - name: image
      type: ociImage
      access:                               # excluded – rewritten on transfer
        type: OCIIImage/v1
        imageReference: ghcr.io/stefanprodan/podinfo@sha256:8fa5691d768ef456...

    digest:                                # content identity – input to descriptor hash
      hashAlgorithm: SHA-256
      value: 262578cde928d5c9eba3bce0...

  signatures:                             # signature: one hash over the canonicalized descriptor
    - name: acme-release-key
      digest:                              # of the descriptor
        hashAlgorithm: SHA-256
        value: a4b1c2d3e4f5...
      signature:
        algorithm: RSASSA-PSS
        value: <hex-encoded signature>
```

OCM IN ONE PICTURE

Pack · Sign · Transport · Deploy



COMPOSE

Service carries resources. Product carries references.

Service components carry resources — images, charts, configs, SBOMs, ...

A product component composes other components. One release unit, transferable, signable end-to-end.

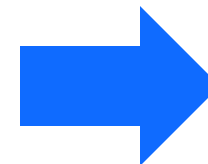
SERVICES

components:

- name: acme.org/sovereign/notes
version: 1.0.0
resources:
 - name: image # OCI image
type, access, digest trimmed

components:

- name: acme.org/sovereign/postgres
version: 1.0.0
resources:
 - name: image # OCI image
type, access, digest trimmed
 - name: chart # Helm chart
type, access, digest trimmed



PRODUCT

components:

- name: acme.org/sovereign/product
version: 1.0.0
componentReferences:
 - name: notes
componentName: acme.org/sovereign/notes
version: 1.0.0
 - name: postgres
componentName: acme.org/sovereign/postgres
version: 1.0.0

no resources of its own — pure composition

SIGN

Same signed object. Three signing options.

RSA

Bare public-key pinning.
If you already rotate a signing key.

OPENPGP

OpenPGP keys, ASCII-armored.
If your team runs a keyring.

SIGSTORE

Keyless via OIDC + Rekor.
If you already trust your identity provider.

CTF = Common Transport Format — a filesystem-based OCM repository, portable via any transfer mechanism.

TRANSPORT

Three patterns. One command.

REGISTRY → REGISTRY

Promote across stages.

Source registry to target registry.

REGISTRY → CTF

Export to a local archive.

Hand-carry across the boundary.

AIR-GAP

CTF → REGISTRY

Air-gap import.

Verify on arrival. No callback to source.

DEPLOY

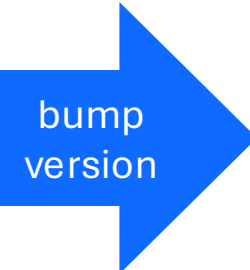
OCM controllers verify and apply.



DAY 2

Bump the product version. Everything follows.

```
component:
  name: acme.org/sovereign/product
  version: 1.0.0
  componentReferences:
    - name: notes
      componentName: acme.org/sovereign/notes
      version: 1.0.0
      digest: # of the referenced component
        hashAlgorithm: SHA-256
        value: 7a1b2c3d4e...
    - name: postgres
      componentName: acme.org/sovereign/postgres
      version: 1.0.0
      digest:
        hashAlgorithm: SHA-256
        value: f5e4d3c2b1...
  signatures:
    - name: acme-release-key
      signature:
        algorithm: RSASSA-PSS
        value: a4b1c2d3e5f6789abc012345def04691...
```



bump
version

```
component:
  name: acme.org/sovereign/product
  version: 1.1.0
  componentReferences:
    - name: notes
      componentName: acme.org/sovereign/notes
      version: 1.1.0
      digest: # of the referenced component
        hashAlgorithm: SHA-256
        value: 9b8a7c6d5e...
    - name: postgres
      componentName: acme.org/sovereign/postgres
      version: 1.0.0
      digest:
        hashAlgorithm: SHA-256
        value: f5e4d3c2b1...
  signatures:
    - name: acme-release-key
      signature:
        algorithm: RSASSA-PSS
        value: 9c2af18b3e7d52914a8c6b0f1d2e8f37...
```

Every digest pinned by the signature. The cluster cannot drift.

ADOPTION

Two paths to a first OCM component.

FROM ZERO — CLI

Pack one component. Sign it.

Air-gap CTF round-trip.

Verify on the other side.

ON YOUR CLUSTER — CONTROLLERS

Helm-install the OCM controllers.

Point them at your registry.

Deploy a component.

WHAT'S SHARP

Three honest edges.

- **Transfer defaults** — copies only the descriptor. For air-gap, pass `--copy-resources` so the bytes travel too.
- **Controllers are v1alpha1** — the CRD surface can move. Pin to specific release tags in your platform installs.
- **Helm-deploy adds kro + Flux or ArgoCD** — the OCM controllers don't ship them. Bring your existing GitOps engine.

Ship the release as one unit.

Evaluate — ocm.software (QR code) · run conformance/scenarios/sovereign

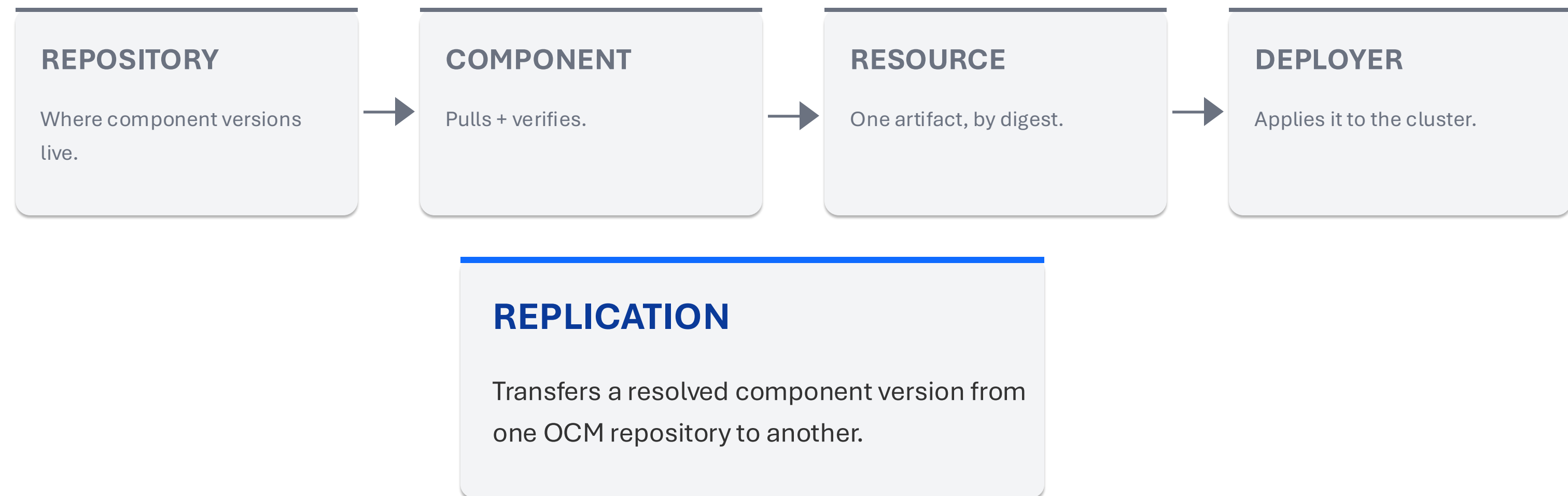
Pilot — github.com/open-component-model · one product, one team

Engage — community channels on the website · NeoNephos Foundation



APPENDIX · REPLICATION

Alongside the chain. Not within it.



Controller-shaped equivalent of OCM CLI ``ocm transfer cv`` — point it at a source ``Component`` and a target ``Repository``, and it keeps them in sync.

HOW OCM COMPARES

Composes with what's there.

	WHAT IT SIGNS	LOCATION-INDEPENDENT	AIR-GAP NATIVE
cosign / sigstore	one OCI artifact	no	no
SLSA / in-toto	one build's provenance	no	partial
SBOM / OCI 1.1 refs	one artifact's contents	partial	no

OCM **a component (the bundle)** **yes** **yes**

OCM rides on top. It doesn't replace the per-artifact tools — it adds the release-level envelope they don't.

APPENDIX · ABBREVIATIONS

Quick reference for terms used in this deck.

CSI — Common Service Infrastructure — SAP-internal shared services platform.

Helm — Package manager for Kubernetes; reference artifact type for OCM.

NeoNephos — European foundation for sovereign cloud open-source projects (Linux Foundation Europe).

OCI — Open Container Initiative — open standards for container image format and distribution.

OCM — Open Component Model — vendor-neutral specification for signed, transportable software components.

OpenPGP — Open standard for cryptographic signatures (RFC 4880). GPG is one implementation; Sequoia and RNP produce compatible signatures.

RSA — RSA / RSASSA-PSS — bare public-key signing scheme. Trust model: operator pins the public key. No PKI required.

SBOM — Software Bill of Materials — inventory of components and dependencies inside a software artifact.

Sigstore — Open-source project for keyless software signing using OIDC identities + Rekor transparency log.